Case Analysis: Red Cross Data Breach

The breach of the International Committee of the Red Cross (ICRC) is a highly complex case, including the preceding factors and the aftereffects. The organization is not a typical software producer, but does create software solutions for a variety of users to achieve its mission. Its users are comprised of a heterogeneous mix of international organizations, field staff, and end-users, all of whom depend on the software for critical and even life-saving operations. The end-users, called beneficiaries, are of particular importance, and they are the people that benefit from the services provided by the ICRC in disaster situations like violent conflict and environmental disaster. With their iconic Red Cross emblem, the ICRC provides a variety of services to their beneficiaries, including reconnecting families who have been separated, which they have done for over 150 years. Today, this means implementing and deploying software through their Restoring Family Links (RFL) program, which is deployed by field staff worldwide. The regulatory regimes that apply to the ICRC and its users are manifold, including disparate national requirements in the countries where they work, and international agreements like the Geneva Convention.

In 2021, a breach compromised information about 515,000 beneficiaries of the RFL program. These end users are a particularly vulnerable population, and malicious use of their data could lead to direct harm. Additionally, their privacy, diverse situations, and diffuse locations disrupt their ability to recover from the breach, such as through legal action. The regulatory bodies that are tasked with controlling and remediating the breach are also spread out among multiple jurisdictions, making it hard for anyone to act. The ICRC, as the software producer, had to act in the best interests of their mission, which takes into account their future operations and the wellbeing of their users, particularly, the beneficiaries. Ultimately, the state of data protection and privacy as it relates to humanitarian aid is challenged.

1 Cyber Social Context

The broad context that sets the stage for the cyber incident that occurred is made up of three environments: **regulatory, threat, and operational**. There are inputs to- and outputs from each of these environments that relate to each stakeholder. Inputs to the context come from the industry and regulations that have been set previously, and the outputs inform each stakeholder's processes. The regulatory environment is comprised of the various rules and regulations across the jurisdictions where users & producers that operate collectively form a regime that the stakeholders operate under. The operational environment is made up of the day-to-day operations that the stakeholder undertakes using the software to meet their needs. The threat environment is made up of the risk of an incident, the stakeholder's abilities in securing their operations, and more.

1.1 Software Producer

The ICRC, which was founded in 1863, has developed internal software solutions to support its operations, specifically their "mandate and mission" to ensure "humanitarian protection and assistance for victims of armed conflict and other situations of violence", as well as things like natural disasters, as an "independent, neutral organization" (ICRC Mission 1949; ICRC RFL Strategy). One of the programs of the ICRC is called Restoring Family Links, "Restoring Family Links (RFL) is a general term used to describe a broad range of activities carried out by the [Red Cross] Movement to prevent family separation, restore

and maintain contact between family members, and ascertain the fate and whereabouts of missing people. RFL activities include enabling the exchange of family news; tracing missing family members; identifying, registering and following up unaccompanied and separated vulnerable children and others; and arranging family reunification" (ICRC, RFL Strategy 2020-25). They have been doing this work since 1870 through their Central Tracing Agency (CTA) and with the support of the various bodies of the Red Cross Movement partners (described below) work together to support reconnecting families that have been separated.

Given the delicacy of the needs of its end users, the ICRC must adhere to a high standard of protection and security of the data, otherwise they may not be able to meet their goals and protect the victims who are beneficiaries of their services. To that effect, they have been recognized for their state-of-the-art security practices (DEVEX, R002 Interview). To operate, the ICRC relies on funding from a variety of sources, including governments, "supranational organizations", and public and private donors. As with any charity, should they fail to achieve their mission, those funding sources may hold back, and the organization would not be sustainable or their operations viable. The ICRC is also not a single, standalone organization. In fact, it is made up of multiple organizations, namely the Red Cross National Societies which operate in individual countries, and the International Federation of the Red Cross, which administers the different bodies. Together, they are collectively called the Red Cross and Red Crescent Movement. In terms of the software, the ICRC provides the National Societies with the tools they need to conduct operations in their host countries. For RFL, the Movement has implemented and deployed a software ecosystem for beneficiaries to find and contact family if they have been separated.

The threat environment that the ICRC is concerned with for its software is not widely studied. Given the vulnerability of the end users, nefarious actors include the broadest spectrum of adversaries, including states, criminals, and hacktivists. States may seek to compromise the data of beneficiaries to gain leverage in a conflict or subjugate people they see as enemies. Criminals may try to exploit the data for financial gain. Hacktivists might try to achieve political agendas with the data of people who are engaged with the ICRC. Because the software is being implemented by various National Societies in various situations, the ICRC must control for a variable threat surface that changes with the circumstances where the software is being used. To deal with this, their data privacy and security teams have developed knowledge, skills, and practices specific to their needs, resulting in familiarity with vulnerabilities that are internal to their domain. The ICRC has been recognized for their expertise in cybersecurity, demonstrating a familiarity with the cyber threats endemic to their field that is valuable to protecting their users (DEVEX, R002 interview).

Part of implementing their software operations, and responding to the threat environment, is fitting within the regulatory spaces that govern them. The ICRC and the Movement partners are bound, at the highest level, by the Geneva Conventions, first adopted in 1864 and revised multiple times until 1949, and the additional Protocols amended later. The Conventions and Protocols establish international laws for humanitarian treatment during violent conflict. The ICRC is headquartered in Geneva, Switzerland, and must comply with the regulations of that country as well. The National Societies, which implement the software, must comply with the regulatory regimes in their host countries (ICRC RFL Code of Conduct; Le Blond, 2018). In addition to complying with rules that are heterogeneous between each National Society, the host countries may be friendly or hostile towards these operations, complicating privacy and security efforts. The ICRC also identifies multiple other legal instruments & guidance when processing data for RFL, including various international charters, treaties, and conventions (RFL FLN Code

of Conduct). Internal controls are quite stringent, for example National Societies are meant to perform a data protection impact assessment "Where processing is likely to present specific risks to the rights and freedoms of data subjects" (RFL FLN Code of Conduct).

The beneficiaries of the aid may also have their own predispositions to their use of the software, as well as technical obstacles like language barriers, alphabets, and devices.

ICRC Developers (Implementation)

Centrally, the ICRC develops the software, and they create solutions to meet the needs of their National Societies and beneficiaries RFL goals. They have permissions based on their needs to access the data, implement changes, and coordinate with other stakeholders. Hierarchically, they sit towards the top, because they interact with the other users, and the leadership responsible for the organization. Ultimately, they must answer to authorities for their successes and failures. They will also be able to support the implementation and use of the software by the National Society and beneficiaries. Additionally, in this case, the technical teams responsible for implementation may also be the producers of the software, which means they have an unmediated link to software changes.

As the technical experts implementing the software, they are also the closest to understanding the regulatory regimes that govern its use. As issues arise from the other users, they must be able to address questions and conflicts so that they stay in compliance with the regimes in place. There are also technical challenges in complying with multiple regulations; data must be stored, transmitted, and secured in various ways depending on the country. They may face legal challenges with their host country in order to meet their mandate while complying with the regime in place.

Regarding threats, they must be externally familiar with the vulnerabilities consequential to their operations. External familiarity requires developers to be prepared for threat actors' unique ability to exploit users through their acquaintance with user practices in this specific circumstance, such as a domain, country, culture, or language. This means that there is a variable threat surface because of the disparate ways that users use software, creating new vulnerabilities that can be exploited. Threats can be created by practices that aren't controlled for, and these need to be communicated to the software producers. Software developers are also internally familiar with their own systems, and can make security decisions based on their experience with their software.

1.2 Users

There are different types of users that deploy the ICRC software, which could be grouped based on their use cases, permissions, and hierarchically. The users include the National Societies that deploy the software in the field and the end users who are beneficiaries of the RFL program. The field workers are users that deploy the software, and are also closely connected to the software developers because of their relationship to the ICRC. However, the field staff are users who deploy the software in the field and are not responsible for the development of the software. The end users are what the Red Cross Movement, and other organizations, call beneficiaries, because they benefit from the aid provided. These end users use the software to reconnect with their families by providing their biographical information and are then able to send messages and get updates on their situation (ICRC RFL Strategy).

National Societies (Deployment)

The National Societies' software use case includes their operations within the host countries, managing the humanitarian aid they deliver to the victims of armed conflicts and other disasters. They deploy the software provided by the ICRC to meet their mission, connecting families who have been separated. In the hierarchy of stakeholders, they are in the middle, possibly able to relay feedback and questions to the developers, but unable to fully control the software and its requirements. They interact with the end users more directly. This means that their permissions may not include the ability to change the software, like the central developers, but they may have access to the critical data about the populations they are trying to protect. They may be able to access aggregated reports related to their operations.

These operations by the National Societies require heterogeneous practices based on the circumstances of their work: not all National Societies have the same regime requirements, nor do they have the same operational needs.

Due to their heterogeneous practices and their elevated permissions, these users contribute to the variable threat surface as users and implementers of the software, according to R003. They may have different levels of experience using the tools and skills with technology in general. Training in the software and cybersecurity best practices are an important skill set for the National Societies.

Users in this tier may be the most familiar with the national regulatory environment that governs the software. At a minimum, they are the most connected to the regime because they are implementing in the field. They may be the parties responsible for interacting with the regulatory bodies, such as the government and other NGOs. While the technical team may be responsible for implementing changes based on the regime, the National Societies are responsible for understanding their host country and need to communicate the requirements.

Beneficiaries (End Users)

The operational use case of the end users, victims of violent conflict and other disasters, is them entrusting their data to the Movement with the expectation that they get humanitarian assistance and protection, in the form of goods and services. For the RFL software, these services include video and phone calling to their families, as well as other secure messaging. They may have to use devices and technology that they are not familiar with, and provide private information that they need to keep secure. At the bottom of the hierarchy pyramid, there are more of them than any of the other users, and they have the least connection with the software producer and the regulators. They must contribute records of their assistance and protection, as well as personal details, putting them at the most risk, and with the least permissions to access the data, likely only able to retrieve their own or their family's data (RFL Strategy).

The threat environment for these users is that they may be the targets of threats that compromise their safety. By using the software, they provide sensitive information that then becomes vulnerable to malicious actors. Depending on their interaction with the software, they may also introduce vulnerabilities if they do not follow best practices. In a conflict zone, such as a civil war, a host nation may be looking for the people that are using this software, and attempt to hack it to reach them. In an environmental disaster situation, criminals may try to exploit the users for financial gain.

Ultimately, the regulatory environment and its resulting regimes are designed around these end users, whether the goal is to protect the data, or to exploit it. Using the civil war example, a host nation may try

to weaken protections for the users so that they can get access to the data and use it to seek out people of interest. On the other hand, a host country amidst a disaster may adhere to the best practices of the Red Cross to get their best support.

1.3 Regulators

The regulatory environment that the ICRC operates in is complicated, and is further complicated by its development and implementation of tailored software. According to the ICRC, "all States are bound by the four Geneva Conventions of 1949 which, in times of armed conflict, protect wounded, sick and shipwrecked members of the armed forces, prisoners of war and civilians" which extends to the data security and privacy of those people. The additional Protocols are agreed to by many nations, but not all, and add further protections for victims of international and non-international conflicts, and add more emblems beyond just the cross as identification. The Conventions and Protocols provide a legal basis for the ICRC's operations in armed conflicts and a "broad right of initiative" in various circumstances.

The ICRC RFL program identifies other regulations that govern their programs in their Code of Conduct on Data Protection (2015). The regulatory bodies include the Council of Europe, European Parliament, Organization for Economic Cooperation and Development (OECD), Asia-Pacific Economic Cooperation, and the Global Privacy Assembly, in addition to their own internal statutes and codes which are also legally binding. These bodies have established rules, regulations, guidance, frameworks, and other legal instruments that ICRC has agreed to adhere to (RFL, 2015). Ultimately, this paints a complex landscape of both organizations and practices that guide data privacy and security.

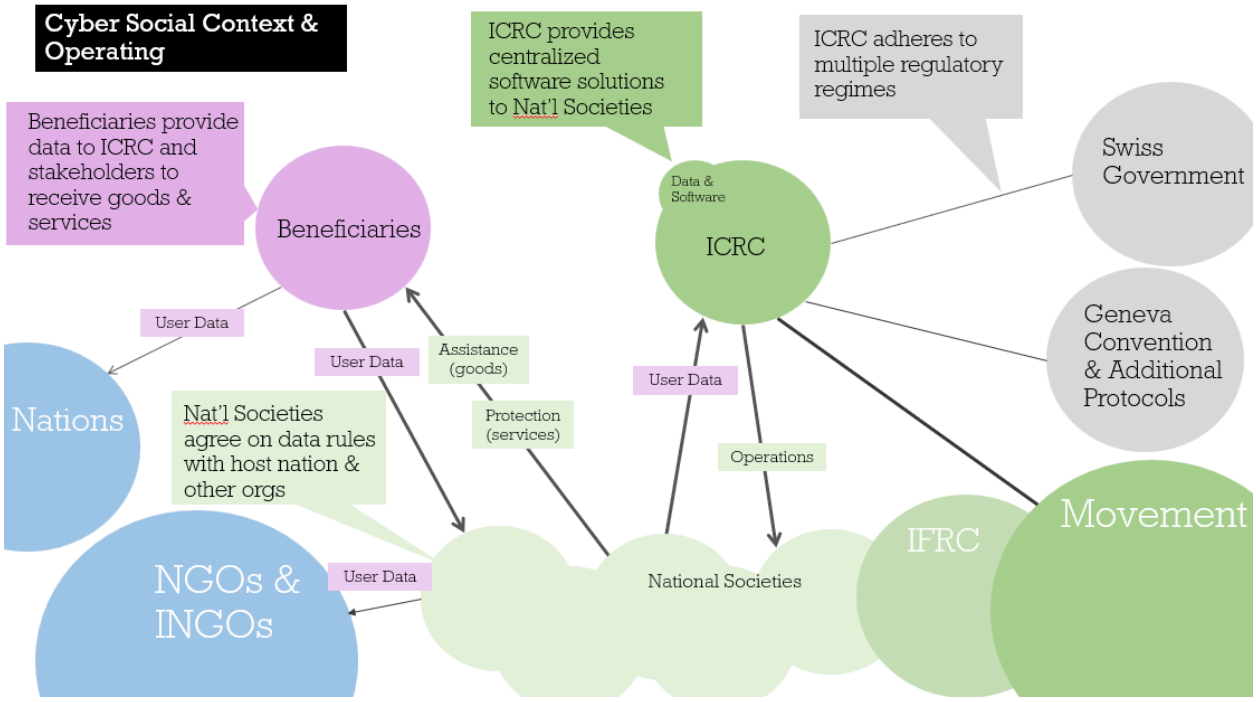
Host countries set forth regulations that the Movement must comply with in implementing the software. There may also be non-governmental organizations and inter-governmental organizations that regulate the behavior of the Movement and its bodies. These different countries and organizations may have different, even contradictory rules, for the ICRC and the National Societies involvement in a conflict, and with their use of software. Some of these rules may be more favorable than others for meeting the needs of the beneficiaries (R003).

Together, these regulators and their rules yield an emergent regime that governs the behavior of the Movement, including its software implementation. The regime is comprised of overlapping laws, rules, and regulations, as well as the current political climate, changing governments, legal history, human and capital resources, opinions towards the ICRC, or sentiments towards the beneficiaries. Because this work is often conducted in a conflict zone, there also may be contradictory requirements placed on the software producer and its users (Le Blond et al, 2018). Due to these factors, an emergent regime is not easily navigable. While any regulatory body may define their rules clearly, their operational ability to enforce their rules and their methods of enforcement will vary. They may be limited by superior jurisdictions or by human and capital resources.

Regulatory bodies also have their own familiarity with vulnerabilities that are unique to them, such as their domain or territory. They may have developed expertise in dealing with these threats, both pre-emptively and in post. Alternatively, they may be unfamiliar or unprepared, therefore exposing vulnerabilities, and unable to remedy the harms caused by attacks. For example, the Red Cross has been providing aid since its inception in the mid-nineteenth century, and the Geneva Conventions date back to WWII, and their ability to protect the data privacy of the people that are in their purview may not be as advanced as the threats that exist.

The ICRC, as part of its mission, also adheres to its own internal regulations, which include impartiality, independence, and neutrality. These directives help the organization operate in conflict zones by never giving preference to one side, thus being able to provide aid to any party in a conflict, and helping make sure that it is not attacked during its operations. Internal regulations may not always be a legitimate source of rules, however, in this case, the Movement depends on these internal controls in order to continue operations. The Movement's various bodies are somewhat independent of each other, which adds to their ability to self-regulate (R003).

For a national government, ultimately, the regulators and their regimes are meant to support the political interests of the governing body. For a democracy, that means protecting the users who are their citizens and constituents, as well as the businesses critical to the economy. For an autocracy, that means protecting the interests of the ruling party. In conflict zones, the National Societies must balance the interests of their beneficiaries while complying with the requirements of stakeholders who are actively engaged in violent conflict.



2 Operating

The operating phase reflects the typical business and organizational processes in developing, using, and regulating the software. For the developers and the users that are responsible for the software, particularly in this case, these operations are comprised of **implementing or deploying, securing, and adhering/complying**. For regulators, operations include **regulating** and **bureaucracy**.

2.1 Users

Users and software producers frequently have aligned goals: deploy and implement software to support their operations, keep the software secure, and meet regulatory requirements. In this case, their goals are particularly aligned given that the users deploying the software are subsidiaries of the organization that developed it. The users in this case include the ICRC Movement partners that deploy the RFL software, and the end users that use it for its intended purpose: "prevention of family separation and disappearances and maintaining family contact, searching for missing persons, providing answers to families, restoring family links, providing support to families during the search, and supporting family reunification (RFL Strategy 2020-2025).

2.1.1 Deploying

In 2022, the RFL program facilitated 2.2 million phone calls, found 12,500 people, and reconnected 4,700 people with their families (ICRC Family Links Network webpage, accessed 2022).

2.1.2 Securing

Users would be responsible for some amount of security, in addition to the developers of the software. Particularly the staff tasked with implementing the software, making sure that they followed the best practices established by their software producers, and general cyber security hygiene. Managers also should be tasked with ensuring their teams are adhering to best practices as well.

2.1.3 Adherence/Compliance

Users, particularly the field staff, would be responsible for helping to ensure they met the regime guidance and rules that governed their operations. Guidance like the Data Protection Code of Conduct was provided for deployment users.

2.2 Software Producers

In 2021, ICRC's day-to-day operations served millions of people through 100 delegations and missions in over 100 countries, with a staff of over 20k+ people. In terms of their RFL services, this includes millions of phone calls and thousands of reunified families (ICRC Annual Report 2022). The ICRC technical teams develop and support information technology tools for these delegations because they may not have the resources to do this themselves (Interview R003). Achieving this required the development and implementation of software. Users around the globe had different needs, and it was the duty of the ICRC as the producer of the software to meet those needs, adapting to changes, providing training, and supporting implementation as the organization pursued its mission.

2.3 Implementing

The Restoring Family Links (RFL) services that the ICRC and its National Societies provided to beneficiaries, included a suite of tools that used a case management system. This case management system was built, in part, using a commercial software called Microsoft Dynamics. The Dynamics implementation is developed, supported, and maintained centrally by the ICRC, for Movement partners to deploy for RFL operations and business/mission needs. The digital transformation effort that was rolled out to bring the various RFL implementations into a more connected and secure environment that used Microsoft Dynamics, started in 2008, with the first implementation launching in 2013, and expanding to over 70 countries since then (Interview R003).

2.4 Securing

The software producers necessarily spend some of their time securing the software from threats. This means preparing for, defending against, and preventing cyber-attacks. An interviewee (R002) familiar with the organization's security practices said that ICRC was operating at a high level to protect their data. Patching new vulnerabilities, ensuring new features are properly secured, and training their clients (users that deploy the software, mainly the National Societies) on best practices.

2.5 Adherence/Compliance

Software developers would help make sure the software was capable of meeting these non-functional requirements. For these parties, adherence would mean that they are doing their best to abide by the spirit of the regime. Compliance would mean that they are merely sticking to the defined requirements. In this case, an example of adherence would be their consummate dedication to neutrality, impartiality, and independence in implementing the software. Compliance might mean minimally following the guidelines prescribed by their host country so as not to upset them, but avoiding actions that might compromise their work when the rules are not clear.

The ICRC has a number of compliance-related artifacts available for analysis, including legal requirements, planning documents, and practical tools. For example, the National Societies that deploy the software also sign service and licensing agreements with the ICRC (Interview R003). The November 2015 Code of Conduct on Data Protection is available as "one tool for all members of the Movement to use with regard to protecting fundamental rights and freedoms of individual, in particular the right to privacy and the protection of personal data, affected by RFL activities" (ICRC 2015). This in-depth artifact includes details about topics like Lawful and Fair Processing, Rights of Data Subjects, Special provision on Data Transfers, Legal Instruments/Guidance and Doctrine. From this document, further practical artifacts have also been created, including the Data Protection Compliance Checklist, which can be used by the National Societies to "identify whether the quality of service to beneficiaries meets the minimum requirements for data protection set out in the code" as well as a Template for Data Protection Impact Assessment (DPIA). Additional documentation, including the RFL 2020-2025 Strategy and a progress report for 2012-2015 include data protection as a foundational principle for RFL deployment by Movement partners.

2.6 Regulators

The operations of regulators differ from that of software producers and users. They do not always get involved in day-to-day operations of parties, even if they are regulated, unless some conflict or event has already occurred. However, some agencies, particularly self-regulatory bodies, may perform audits and oversight duties in regular intervals. In their regulatory duties, the agency may support the development of new rules, collect input on rules, and monitor reports of conflicts. They may also engage in bureaucratic activities, promoting the interests of their agency to meet their own goals.

Regulators that are stakeholders in the ICRC's software implementation come from a variety of jurisdictions, regimes, and politics. The Red Cross/Red Crescent Movement must be cognizant of the dynamics of these stakeholders and their rules in order to deliver their services. The countries where they operate have unique requirements that must be met and it would be under the purview of the National Society in the host country to ensure that they comply with those requirements (Le Blonde,

2018). This presents technical challenges to implementing the software in-country, as they need to adhere to unique regimes in each scenario. Regulators may have requirements that compromise the integrity of the ICRC data, meaning that the host country's objectives are at odds with the ICRC's mission, and putting its beneficiaries at risk.

3 Precursors

The net effects of the operating practices and activities of each of the stakeholders, described above, are the precursors to the cyber attack of the ICRC. These are the outputs of their operations, and the inputs to the adverse event that occurred. For users and software producers, the net effects of their practices align. The net effects of their operations are **knowledge & experience**; **business change**; **adherence & compliance**; and **unaddressed failures & weaknesses**. While net effects for user & producer stakeholders are similarly coded, the practical outputs differ. For example, both users and software producers generate knowledge and experience from their operations, but the outputs of that knowledge and experience for software producers might include software engineering artifacts that are not relevant or necessary for users. Instead, users' knowledge and experience is typified by the deployment of the software, not its underlying codebase.

The key outputs of regulatory operations are regimes. Regimes are comprised of the jurisdictions, laws, regulations, rules, guidance, recommendations, and politics to which the users and software producers are beholden. Regulatory regimes arise from multiple levels of society, including local, national and supranational governments, and industry self-regulation. They are imbued with a range of powers, ranging from limited to forceful. Regulatory bodies can be purely observational, able to convene stakeholders, directly monitor behaviors, and enforce rules directly. These outputs are highly dependent on the context and the specific case. In this case, the regimes varied based on the host nation where the Red Cross National Societies were operating, and the Swiss government where the data was stored. The host-nations likely created a variable environment, while the operations in Switzerland were likely to be routine.

3.1 Users

As discussed above, there are parallels between deployment users and software producers in their actions and the results of those actions: their operations have net effects. Below are the broad net effects of their operations based on the outputs of practices and activities. These outputs and net effects were ultimately the inputs to the adverse event, a data breach.

3.1.1 Knowledge & Experience

Users's knowledge and experience are derived from their operations described above: deploying, securing, regulating, and complying. The culture of use of the software, whether it is accepted or rejected (or something in between), is also a result of the context and operations, and can vary across the hierarchy of users. Top-level users responsible for deployment may see the value in the software, while end-users may see it as a threat.

3.1.2 Business Change

Users and software producers may induce changes to the software. Users may request new capabilities based on their unique scenarios. Producers may release new features to meet the needs of users that deploy the software, to anticipate future needs, or based on data collected from the users. For ICRC this

means responding to the needs of National Societies including high-level and on-the-ground requirements. These changes, including to processes and software functionality, can add to the threat surface by introducing new vulnerabilities, both technical and non-technical. Software updates and changes to code in the process of day-to-day operations can result in new vulnerabilities that may be compromised by technical adversaries. Changes to workflows and business processes can lead to user errors that can be exploited.

External vendors and their processes also need to be examined to ensure that they are adhering to the rules, and following their own security practices when dealing with ICRC data.

3.1.3 Adherence & Compliance

There is a gap in the role of users and software producers in regulatory compliance practices. In this case, among the users, it is primarily the middle- and upper-tiers that are responsible for compliance. The end users are a particularly vulnerable class, with extremely limited resources to participate in compliance with regulations, before, during, or after a violation. The National Society staff users are responsible for complying with regulations in their host country.

In adhering and complying with these regimes, both groups of stakeholders generate artifacts that document their efforts. This would include both formal and informal compliance documentation. Respectively, standardized artifacts that can be submitted to regulatory bodies and other preserved records (like emails) that demonstrate their operations.

These artifacts may need to be reported to authorities regularly to demonstrate compliance. Various regimes may require them, including different levels of government, self-regulatory organizations, and internal teams.

3.1.4 Unaddressed Failures & Weaknesses

The summary net effect of these operations, and the other precursors, is an unaddressed failure or weakness that was exploited by an adversary. Amongst users, this would derive from inadequate training or experience, a mistake, which exposed a vulnerability to a malicious actor.

It is possible that either end-users or administrators have their accounts compromised, which can then be used for cyber attacks. The compromised accounts can be used by malicious actors to exploit vulnerabilities. This could mean that a beneficiary has their information compromised, which could reveal personal information about themselves or their families. It could also mean that an administrator user is compromised, which could include access to multiple end-user data or other administrative capabilities that could lead to harm.

3.2 Software Producers

3.2.1 Knowledge & Experience

The ICRC developed their software tools to meet their mission, which incorporates the broader goals of the Red Cross Movement and the specific needs of the National Societies to deliver RFL services. This means industry-specific knowledge and experience to deliver to the hierarchy of users in the Movement. In implementing this software, they have accrued artifacts including documentation, reusable code, checklists, training materials, and more that are specific to their needs. They have also garnered implicit

knowledge of the field that isn't necessarily documented; skills that are valuable but difficult to pass on to others. Ultimately, the software developers have delivered an engineered software product to their users, incorporating the functional and non-functional needs of their users, based on their knowledge and experience.

3.2.2 Business Change

Producers may release new features to meet the needs of users, to anticipate future needs, or based on data collected from their users. For ICRC this means responding to the needs of National Societies including high-level and on-the-ground requirements (Interview R003). These changes, including to processes and software functionality, can add to the threat surface by introducing new vulnerabilities, both technical and non-technical. Software updates and changes to code in the process of day-to-day operations can result in new vulnerabilities that may be compromised by technical adversaries. Changes to workflows and business processes can lead to user errors that can be exploited.

The RFL program used a case management system based on the software Microsoft Dynamics. Dynamics needs to be updated regularly with patches that support security. A new vulnerability was identified that required such an update by the ICRC software team.

3.2.3 Adherence & Compliance

In 2015, the ICRC released a reference document, *ICRC Rules on Personal Data Protection* "for protecting Personal Data, which will also enable it to remain at the forefront of international humanitarian action, even in the most challenging circumstances" (ICRC, 2015). The document introduces "rules intended to ensure that the ICRC can carry out its mandate under international humanitarian law (IHL) and the Statutes of the International Red Cross and Red Crescent Movement (Statues of the Movement) in a manner consistent with internationally recognized standards for protecting Personal Data."

As discussed earlier, the ICRC also supplies compliance artifacts like their Code of Conduct on Data protection. Their operations have been identified as best practices and likely include things like routine internal and external audits, training, making required security updates such as patches, and more. However, a vulnerability still went unpatched, which later led to their system being compromised.

The software producers at the ICRC are responsible for the challenge of providing the means, in terms of software functionality, for their staff users to comply with legal requirements. The ICRC as software producer must also comply with the other governance required of them by the regimes in which they operate, such as in Geneva where they are based (Interview R003).

3.2.4 Unaddressed Failures & Weaknesses

Ultimately, there was a failure that lead to the breach. It could have occurred amongst the users that deployed the software, or by the software producer. Software producers may have introduced these weaknesses during typical operations inadvertently or negligently, as well as by social or cognitive faults. Inadvertent vulnerabilities often arise from "zero day" exploits, which are utilized by hackers before anyone has the chance to protect against them. Negligence might be the cause if there is a known vulnerability, but the software company does not take the time to patch the software to protect against it. In some cases, they may not have the resources to do so.

In the ICRC case, a unique vulnerability was identified and exploited. The specialized nature of the attack is widely seen to indicate that it was a powerful actor, such as a state-sponsored group and known as an Advanced Persistent Threat (APT), that had extensive resources to expose and exploit this vulnerability (R002; Bleeping Computer, 2022).

3.3 Regulators

3.3.1 Regimes

The outputs of the cyber social context and operations of the regulatory bodies are the regimes that govern the users and stakeholders. These regimes are comprised of laws, rules, regulations, guidance, and recommendations.

In this case, disassembling the regimes that govern the ICRC and the broader Red Cross movement is nearly impossible. In practice, it is left up to experts, and even they may have difficulty fully interpreting and executing the full slate of requirements. It can even be that some requirements contradict each other, not only between regulatory bodies, but even within one itself. A study of the information security practices at the ICRC (Le Blond et al, 2018) indicates that they are affected by "loopholes in legislation," "asymmetric legislation," and legal pressure on their privileges and immunities.

The relationships between the regulators and the other stakeholders could have an impact on the impacts, recovery, and outcomes to the breach in the future.

3.3.2 Knowledge/Information Products

Third-party stakeholders, including government agencies, NGOs, and cybersecurity companies first detected and publicized a flaw known in the US National Vulnerability Database as CVE-2021-40539 starting on September 7, 2021 (ZDNet, 2022; The Record, 2022; BleepingComputer, 2022; MITRE, 2021; NIST, 2021). Multiple US government bodies, along with formal partners like MITRE, detected and analyzed the threat, and made the knowledge publicly available. According to the disclosures by these organizations, the vulnerability is in a popular software called Zoho, specifically their use of additional ManageEngine password management system, and can be exploited remotely by accessing the software's API. A patch was released to fix this vulnerability on September 6, 2021. However, any software implementations that did not employ this patch would remain vulnerable. Further information released by these regulators and third-parties indicates that the flaw was being exploited by Advanced Persistent Threats (APTs), and in particular, APT27, which is connected with Chinese state-sponsored hacking (The Record, 2022).

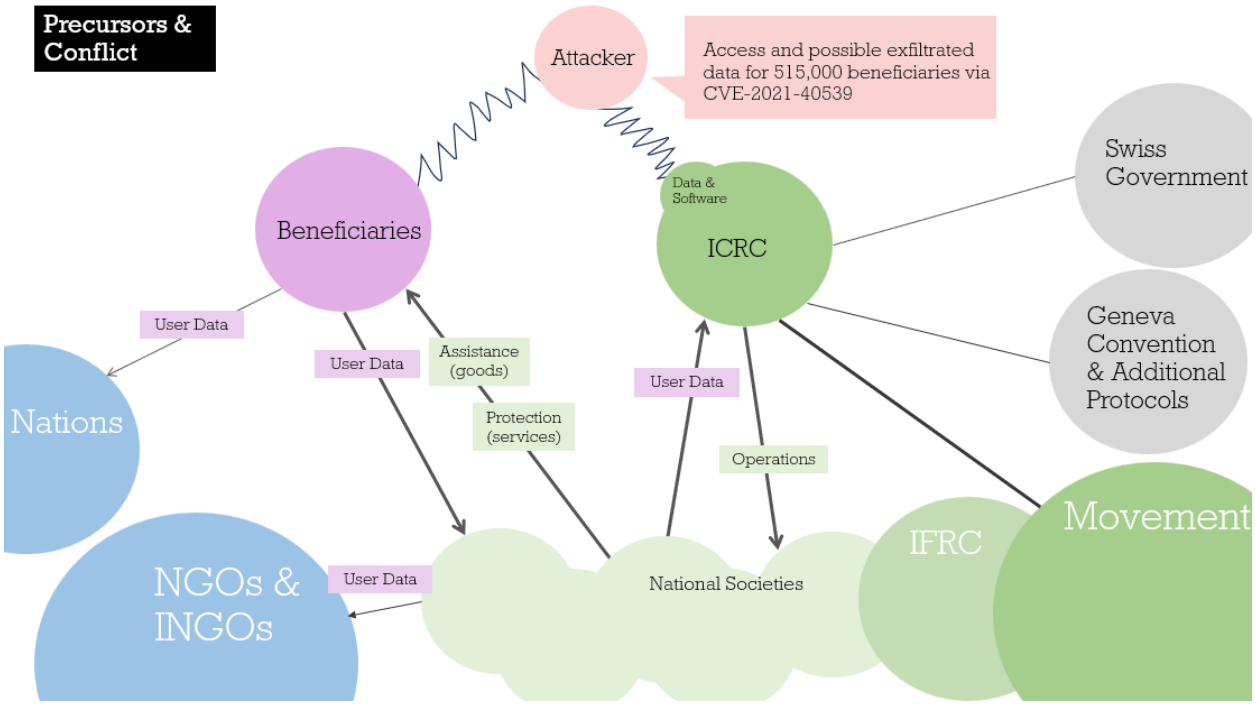
While the vulnerability was initially publicized by cybersecurity organizations in early September, and the patch was released around the same time, there were ongoing awareness campaigns by various stakeholders to help prevent incidents. The US Cybersecurity and Infrastructure Security Agency (CISA), FBI, and US Coast Guard Cyber Command, along with cybersecurity companies MITRE and Palo Alto Networks, issued and updated alerts in September and November (ZDNet, 2022; Bleeping Computer, 2022; CISA, Alert AA21-259A, 2021). The German government issued an alert in January 2022 regarding the vulnerability (The Record, "Red Cross blames hack", 2022; The Record, "German government warns", 2022). In addition to issuing advisories about this specific vulnerability, these government agencies and their partners attributed these attacks to APT27 and connected them with other major attacks which

were condemned by even more governmental bodies including NATO, the EU, and the UK (Bleeping Computer, “State hackers breach”, 2021).

Overall, the scale and potential impact of the vulnerability was clearly understood as soon as it had been identified, and government agencies, as well as their partners, issued intelligence and knowledge publicly to help prevent attacks. These government agencies may not be directly responsible for regulating software producers, but their materials, products, and guidance can be used by other agencies.

4 Incident/Adverse Event

According to the ICRC and multiple reports, starting on November 9, 2021, the vulnerability identified as CVE-2021-40539 was exploited in the RFL systems until it was eradicated and disclosed on January 18, 2022 (ZDNet, 2022; The Record, 2022; ICRC, Cyber Attack on ICRC What We Know, 2022). The vulnerability was in ICRC’s implementation of the Dynamics software, which supports the RFL programs.



4.1 Regulators

Government agencies and formal external partners (such as MITRE) had publicized a vulnerability with Zoho starting in September. However, there is no evidence that the regulators tasked with observing or enforcing cybersecurity requirements engaged with the ICRC.

The stakeholders that identified, analyzed, and disclosed the vulnerability were situated in countries and organizations with the skills and resources required to undertake such tasks. However, they may not have been closely connected enough to the ICRC software developers to get directly involved. Additionally, the users deploying the software were likely to be even further away from those stakeholders, in countries with limited cybersecurity capacity, to ensure that their software was patched based on the intelligence of the vulnerability.

4.2 Users

In this incident, user data was compromised. Users, the beneficiaries of the ICRC's Restoring Family Links program, put demographic and biographic data into the system, and used it to transmit messages. This information could be accessed and collected by the attacker for their own purposes.

Users would have been made aware of the incident according to the regime governing the software producer, often within a few weeks of the vulnerability being identified.

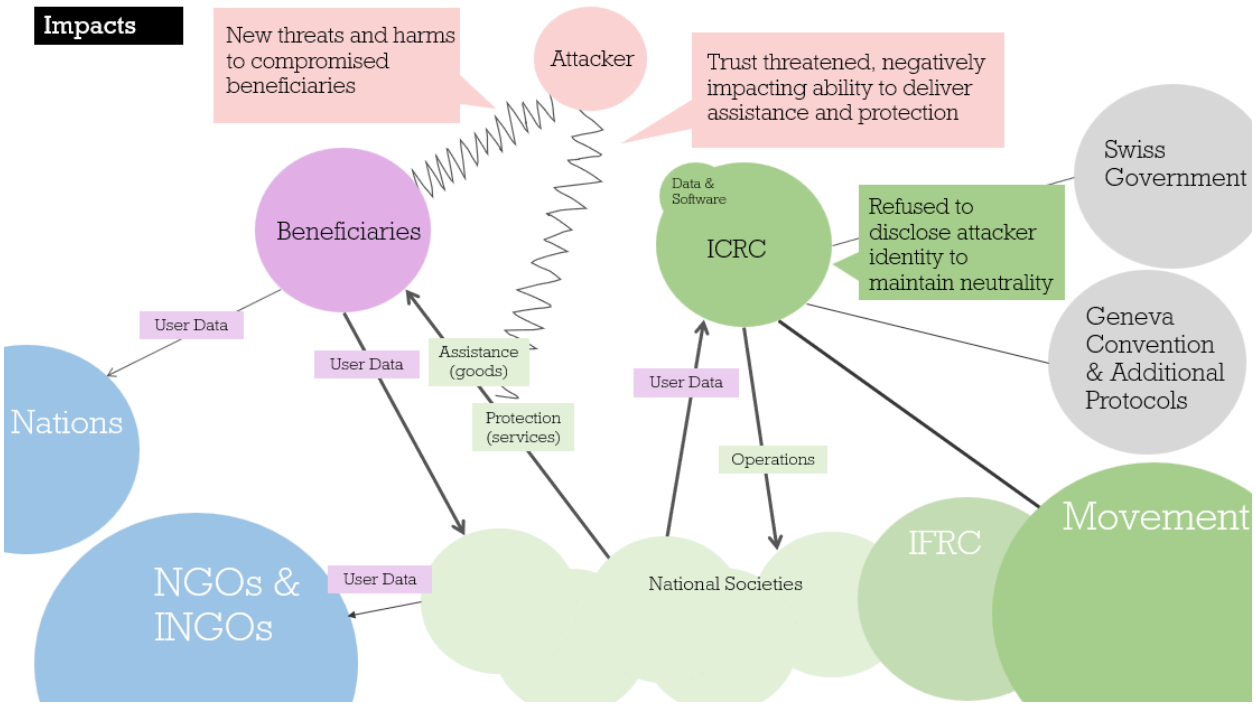
4.3 Producers

The ICRC implemented the software Zoho, along with its requisite chain of software tools to provide its RFL services to beneficiaries. They did not immediately update their software with the patch released on September 6, 2021, leaving them exposed to the vulnerability identified as CVE-2021-40539. This vulnerability was exploited in the ICRC's software in November 2021, around 60 days after it was first disclosed for affected software producers to address. After about 70 days of the flaw being exploited, the ICRC had detected, analyzed, contained, and eradicated the vulnerability. It is likely that they relied on the publicly available information about the breach from other stakeholders to conduct these operations. ICRC stated that "the patching process is an extensive activity for any large enterprise. Annually, we implement tens of thousands of patches across all our systems" (ICRC, 2022).

After the incident had been eradicated, the ICRC began interacting with users and regulators to respond and recover from the event.

5 Impacts

The immediate impact of the incident consists of a few net effects on the different stakeholders. Users and software producers suffered injuries & harms, and may have generated some adherence & compliance documentation, such as logs as well. The regulators at this early stage of the incident are less involved, although they may have made some observations of the event.



5.1 Injuries & Harms

Both users and software producer suffered injuries & harms.

5.1.1 Users

The end-users, totaling 515,000 people, who are beneficiaries of the ICRC and submitted their data to receive support, lost their confidentiality. They are a protected class of people, the survivors of violent conflict and disasters that need help. The other tiers of users, the ICRC staff, also suffered. Their data may have been compromised, and their ability to deliver assistance and protection may have diminished, either through lack of trust of their beneficiaries, or because the compromised data was used to directly subvert their efforts. For example, if the attacker was aware that some beneficiary was attempting to connect with their family, they could use this data to get access to those people and stop the connection from being made.

5.1.2 Developers

The ICRC, the developers of the software, also suffered from the breach. Just like the staff that implemented the software, the legitimacy of the technical team would also be called into question. Their ability to continue their operations as an organization and meeting their mission goals could have been in jeopardy. It is also possible that this breach was covered by a regulation, which could leave them open to further issues if they violated the regime's rules. However, this did not end up being the case. There also would be immediate, direct costs associated with the breach, such as incident investigation, customer notification, and crisis management. Future costs could include regulatory fines and lawsuits, as well as other internal resources to make improvements. At the time of this writing, none of these penalties have been incurred.

5.2 Regulators

Regulatory bodies may also have suffered some harm if their rules were found to be unsatisfactory in preventing the incident. They may also have had to expend some resources to look into the event and determine their course of action.

5.2.1 Observation

Regulators would have observed the event in the course of their duties, and as it was reported to them by other stakeholders. For example, prior to the event, regulators and other third parties issued warnings about the vulnerability that ICRC fell victim to. This failure would have been reported to the relevant regulatory bodies.

6 Responding & Recovering

Below are the practices and actions taken by each stakeholder following the breach. They fall into four categories of strategy: adherence & compliance; posturing; correcting; and compensating.

6.1 Adherence & Compliance

All stakeholders would have had to comply with any rules regarding the aftermath of the incident. In particular, the software producer that suffered the breach, may have had to notify the affected parties. However, these rules vary by jurisdiction, which included 60 countries (ICRC, 2022). It would be impossible to identify the complex regimes that governed the end-users, and even the staff's rights in this case. Not only do I not have the records of the affected people, but I also cannot enumerate the rules in place that protect them between the jurisdictions where they may be protected. Regardless, it is the ICRC's adherence to the spirit of the law that was most observable. They immediately responded by broadcasting pertinent details of the situation to the affected users, their constituents in the Movement, and the public.

It is not clear what end-users would have had to do, if anything. However, if they sought compensation such as through a lawsuit, they would have to comply with rules like a statute of limitations on how long they have to respond, and what remedies are available to them.

Regulatory bodies responsible for the pertinent regimes would have to initiate their processes to observe, investigate, and determine a course of action as required by their mandate.

6.2 Posturing

The technology and security team at the ICRC addressed the breach publicly quickly and transparently to position themselves as acting in the best interests of their constituents, and demonstrate their efforts. Their public statements to journalists and industry publications addressed critical aspects of the breach. However, they shied away from making bold or accusatory statements, such as indicating who might have been behind the breach, other than that it was likely a state actor. This can be seen to be in line with their mandate to remain neutral. Colleagues in the humanitarian data network of the ICRC also spoke in favor of their efforts to prevent the attack, explaining that they have industry-leading data protection policies and practices (DEVEX, 2022) and this was reinforced by interview R002. The Movement also issued a new resolution which condemned these types of attacks, called on states and

other humanitarian orgs to cooperate on data protection, and pushed for resources to prevent future breaches.

In this case, the affected individuals are actually largely represented by the Red Cross Movement. The Movement acts as an advocate for their beneficiaries, and made public statements about the attack, condemning the attackers (whomever they may be) and calling for accountability. Other network advocates for people disenfranchised by conflict, such as USAID, issued similarly critical statements on the attack (DEVEX, 2022).

No regulator directly responsible for the ICRC seems to have made any public statements. The ICRC is largely governed by complex international agreements, and their efforts, as described above, seem to have forestalled any posturing by regulators. There did not seem to be any attempts to reprimand the organization such as by threatening an investigation or signaling their jurisdiction to act.

6.3 Correcting

Once the attack was stopped, the ICRC immediately began a long-term campaign to correct the shortcomings that led to the breach through changes to their business processes, regardless of the effectiveness of their prior prevention efforts. According to the Central Tracing Agency, "a major global effort was needed to keep the services running while these tools were offline, to rebuild secure systems and support National Societies and ICRC delegations struggling to cope with the consequences of the attack" (CTA, 2023). The Movement drafted and affirmed a new resolution, CD/22/R12, *Safeguarding humanitarian data.* It called for the organizations to address security needs, commit to changes to enhance security, contribute resources where needed, create new working groups, share practices, and more. They also led a symposium on safeguarding humanitarian data, where the breach, and other topics, would be discussed (ICRC, Symposium, 2022; Interview R002). Additionally, ICRC developed a new Delegation for Cyberspace in Luxembourg, in partnership with CERN. This created a new experimental space for software development for the ICRC.

In this case, the Movement, which includes the broader Red Cross stakeholders, acts as the users of the software, even if they don't comprise all of the end-user beneficiaries. The resolution, described above, includes their commitment to correcting the business problems that may have led to the breach. This could include improving the physical, information, cognitive, and social dimensions of their cyber resilience (Linkov et al., 2013).

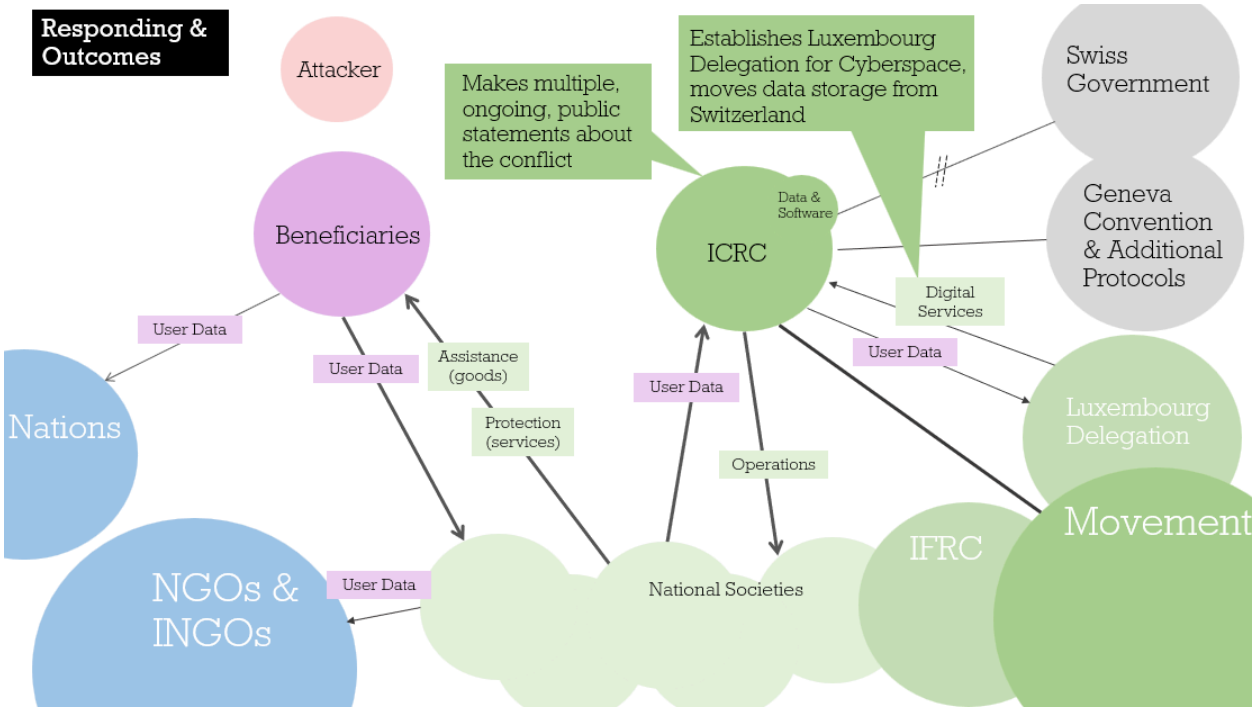
The Movement is so wide, some of its bodies are also external to the software producers in the ICRC, and act as self-regulators. Their affirmation of the resolution can be seen as a self-regulatory correction, although the enforcement mechanisms are not publicly available. State or international regulators have not acted in response to the event.

6.4 Compensating

There is no evidence of compensation sought by the users, offered by the software producers, or mandated by regulators.

7 Outcomes

The Outcomes of the above strategies and practices below fall into four Net Effects: costs; transformations, remedies, and preservation. These net effects are comprised of various outputs from the response and recovery practices, and serve as inputs to the aftermath of the event.



7.1 Costs

The costs to the end-users are somewhat indeterminate. Beneficiaries offered critical information about themselves beyond even basic definitions of personally identifiable information. Data about their families, health, location, personal history, and more were compromised, and this puts them at risk of harm from actors who want to use that data for nefarious purposes. For these passive users, those costs largely come in the form of risks of future harm. Whoever has that data now has it to use to achieve their goals.

For the deployment users, costs include training and adoption for improved processes to prevent against a future breach. The breach may have also exposed vulnerabilities with these users that could be exploited in the future as well.

For the ICRC organization that developed the software, it is likely that the largest cost was remediation of their business processes and technical implementation to prevent a similar event in the future. Given that their data privacy and security efforts have been heralded as being top-notch, the costs are likely to be a complex mix of human and capital resources. The most obvious cost is the establishment of the new delegation in Luxembourg, which required technical and legal resources. Technically, migrating their operations, physical infrastructure, and data. Legal costs include the agreement with the Luxembourg

government. There does not seem to be any direct payment to beneficiaries as compensation for the breach.

Regulators may have spent some resources investigating the breach, but there is no public record to evaluate the time or money spent. However, the new Luxembourg delegation required regulators there to establish the agreement between them and the ICRC. Going forward, there will be some costs to regulating the ICRC's cyber operations which are now based in that country. There is also an analysis that the failure of the Swiss government to provide the regime that met the needs of the ICRC in their cyber operations had an indirect economic cost, because the operations were moved out of Switzerland (Fichter, Republik, 2023).

7.2 Transformations

It is unlikely that the end-users were able to make any substantial transformation to the way that they interacted with the ICRC and its software. However, they may be disinclined to work with the organization in the future because of heightened awareness of the risks.

The technical implementation users, as documented in the Resolution, have updated their business and security practices in order to prevent future breaches. This includes better adherence and compliance with guidelines and rules that are highlighted in the *Handbook on Data Protection in Humanitarian Action*. They may have also organized with other partners to enhance their network and improve their security, such as cybersecurity companies and cybersecurity advocates.

The ICRC as software producer made business process transformations, most notably, the development of the Cybersecurity Delegation in Luxembourg, a novel initiative. It is likely that there were more internal transformations that have not been documented publicly. However, the drastic decision to move software development operations out of Switzerland cannot be understated. As discussed, the ICRC is seen to be a model for cybersecurity processes, so this output of their transformation is remarkable. The end result is a new jurisdiction under which they will operate.

Government regulators, which did not appear to act, did not establish any case law or create new regulations in direct response to the breach. However, the new jurisdiction that the ICRC will operate did result in a new agreement on regulating their data privacy and protection operations.

7.3 Preservation

7.3.1 Users

There is no way to know how many of the end-user beneficiaries continued to work with the ICRC, but out of 515,000 people whose data was compromised, it is possible that there were some differences in their response. Those who stuck with the organization sought to preserve their support and services and made no change to their use. Others may have decided to preserve their future safety by disengaging with the ICRC.

Deployment teams would have sought to preserve their ability to meet their mission.

7.3.2 Developers

The ICRC software producers would have sought to preserve their position to deliver technology products to the Movement. In this case, they chose to sunlight the details of the breach. This included

hosting a conference to discuss humanitarian data privacy and security, and were able to discuss the incident in an open, but secure environment. They made public statements to the press and through their own channels. This was all in an effort to be open about the event, and that has been seen as a positive (Interview). However, not all organizations choose to do this.

7.3.3 Regulators

Regulators would have sought to preserve the rules that had been set forth if they were deemed appropriate, and maintain their bureaucratic roles. In this case, Switzerland failed in that endeavor as ICRC moved its operations elsewhere.

8 Aftermath

The model for the aftermath is derived from Lucas Kello's *Virtual Weapon* describing the impacts of cyber attacks. Rising in the scale of their effects, the model describes consequences as disruption, revision, and systems change. These consequences can have impacts on the threat, regulatory, and operational environments in the broader social context going forward.

8.1 Consequences

There do not seem to be any social consequences stemming from this event. One example of this lack of impact is a more recent breach of the Norwegian Refugee Council. The lack of change is demonstrated in at least two ways. First, the fact that the breach occurred demonstrates that nothing that any stakeholder did deterred attackers from continuing to attack humanitarian organizations. Second, while this breach is comparable to the ICRC breach, the organization did not follow any of the practices that the ICRC did. This demonstrates that both the security knowledge generated following the event, and the recovery actions taken after, did not sufficiently influence the NRC according to R002.

Overall, in this case, not even the lowest level of change to the context, a disruption, occurred.